

Securing BGP

RPKI, ROAs, Route Origin Validation & BGPsec

A journey from “BGP trusts announcements” to cryptographically protected route propagation



Devashish Gosain

02 What you should be able to explain by the end

- Why ordinary BGP is vulnerable to route hijacks and route leaks.
- How RPKI establishes cryptographic authority over Internet number resources.
- How a ROA becomes a VRP and how routers perform Route Origin Validation locally.
- Why ROV validates the origin but not the full AS path.
- What BGPsec signs, what it guarantees, and what even BGPsec cannot guarantee.

BGP's original bargain: reachability first, trust assumed

p = 203.0.113.0/24

"I can reach p via A"

AS A

AS B

AS C

AS D

**BGP carries assertions about reachability.
Classic BGP does not cryptographically prove them.**

Motivation: one bad announcement can escape globally

YouTube / Pakistan Telecom, 24 February 2008

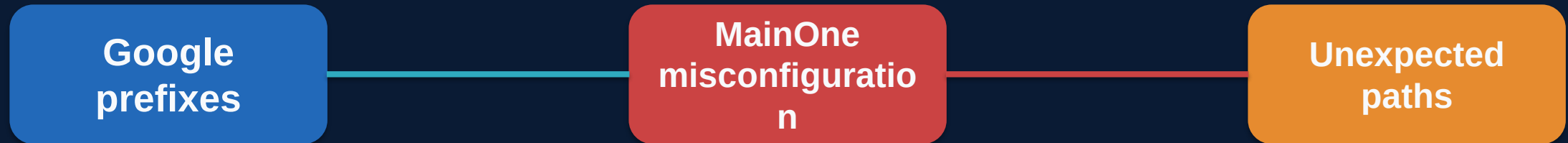


Traffic followed the unauthorized more-specific route.

Source: RIPE NCC RIS case study — unauthorized 208.65.153.0/24 was propagated by PCCW and redirected YouTube traffic.

Not every incident is malicious: route leaks hurt too

MainOne / Google, 12 November 2018



74-minute disruption Traffic was routed over unusual paths and intermediary networks were

Lesson: routing security must handle mistakes as well as attackers.

Two different security questions

1 ORIGIN

Who is authorized to originate prefix p?

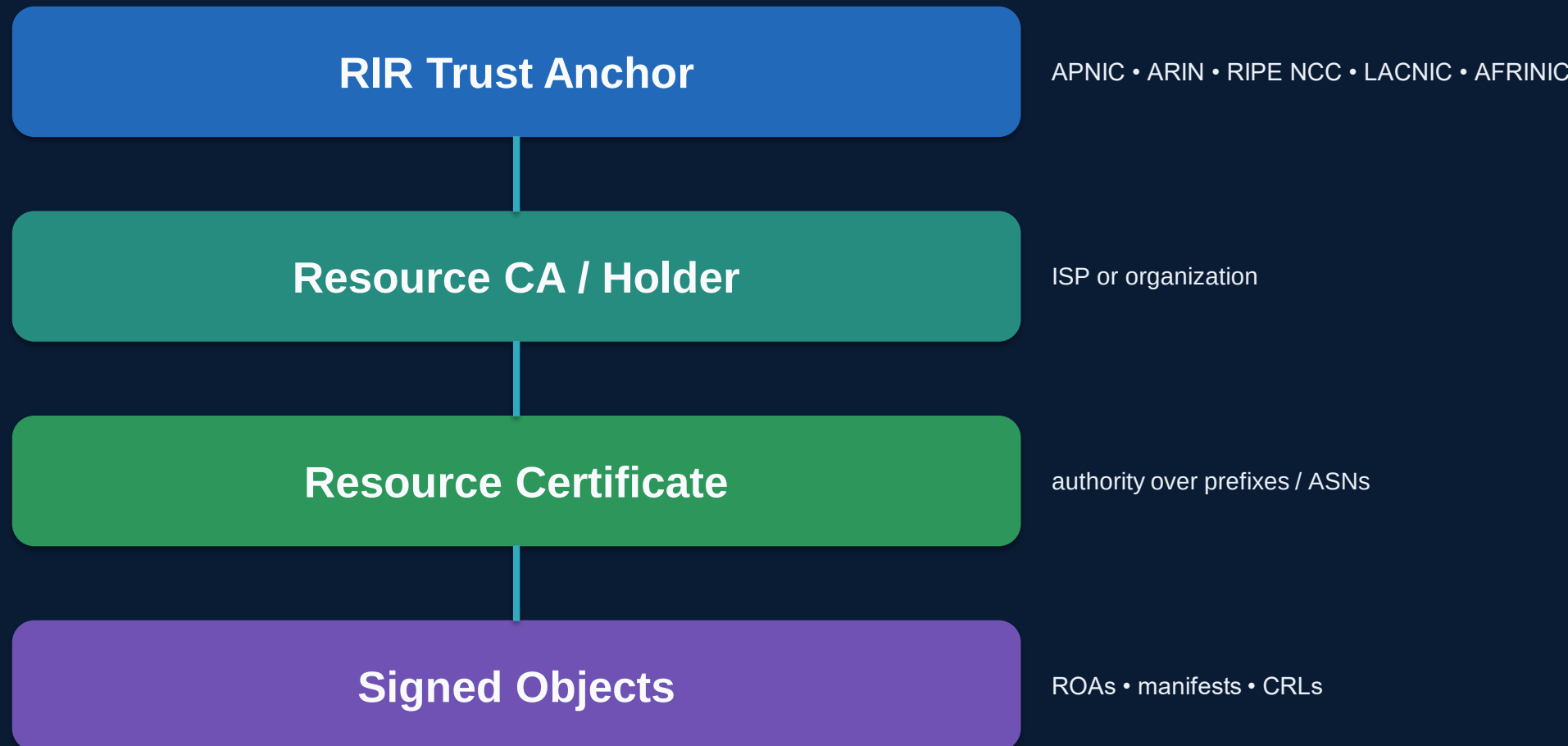
RPKI + ROA + ROV

2 PATH

Did each protected AS really authorize propagation to the next AS?

BGPsec

07 RPKI: a PKI for Internet number resources



The certificate chain establishes who is cryptographically authorized over which resources.

ROA: “this AS may originate this prefix”

Route Origin Authorization

Prefix **203.0.113.0/24**

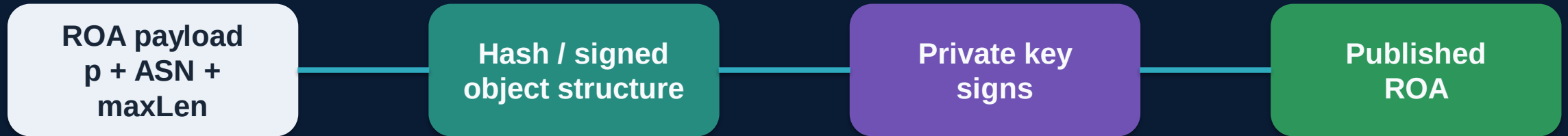
Origin ASN **AS65001**

Max Length **/24**

**Digitally signed
RPKI object**

**Not a BGP announcement.
It is authorization for a BGP origin.**

What “cryptographically signed ROA” really means



Validation is stronger than “signature valid”



Only after the chain and signed object validate does the authorization become usable.

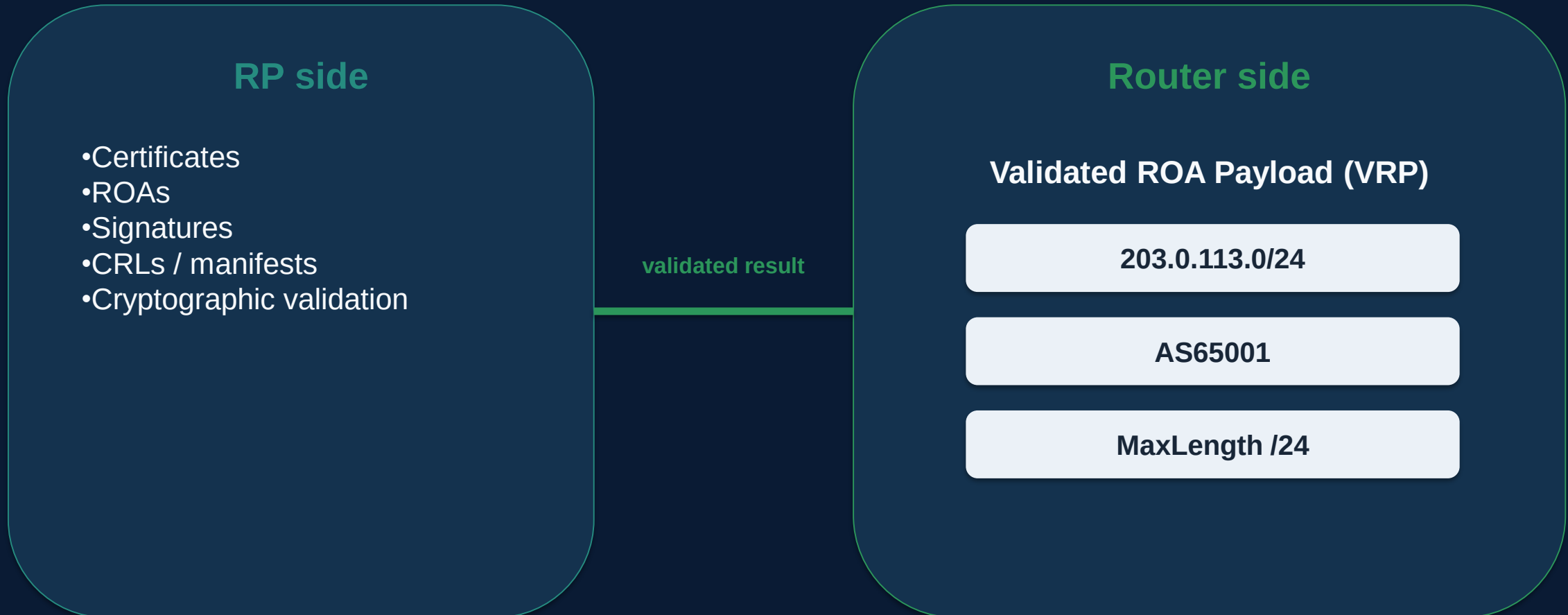
Where does the ROA go? Repository → RP validator



The RP normally runs as separate infrastructure and performs the expensive PKI validation.

RP ≠ per-route oracle

The router does not need the certificates — it needs VRPs



ROV happens locally on the router

BGP UPDATE
p • AS_PATH ... 65001

Local VRP lookup
p • 65001 • /24

VALID

matching prefix + authorized origin

INVALID

covering ROA exists, but route violates it

NOT FOUND

no covering VRP

No per-BGP-update query to the RP.

Why a large VRP set is still practical

A VRP is compact

Prefix
Origin ASN
MaxLength

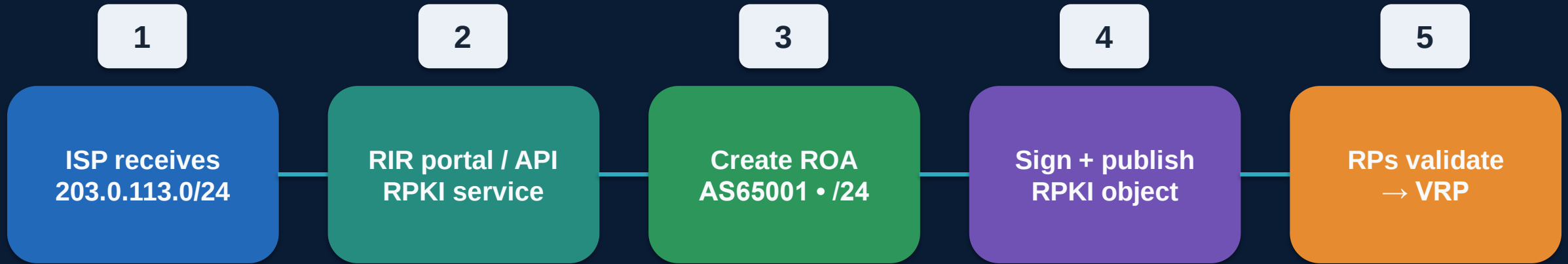
Not certificates.
Not signatures.
Not the full ROA object.

One authorization can cover many announcements



Routers use prefix-oriented lookup structures and RTR synchronization.

14 Operational example: ISP authorizes AS65001



**Creating the ROA does NOT advertise the route.
BGP advertises; RPKI authorizes.**

ROV solves origin authorization — not path authenticity



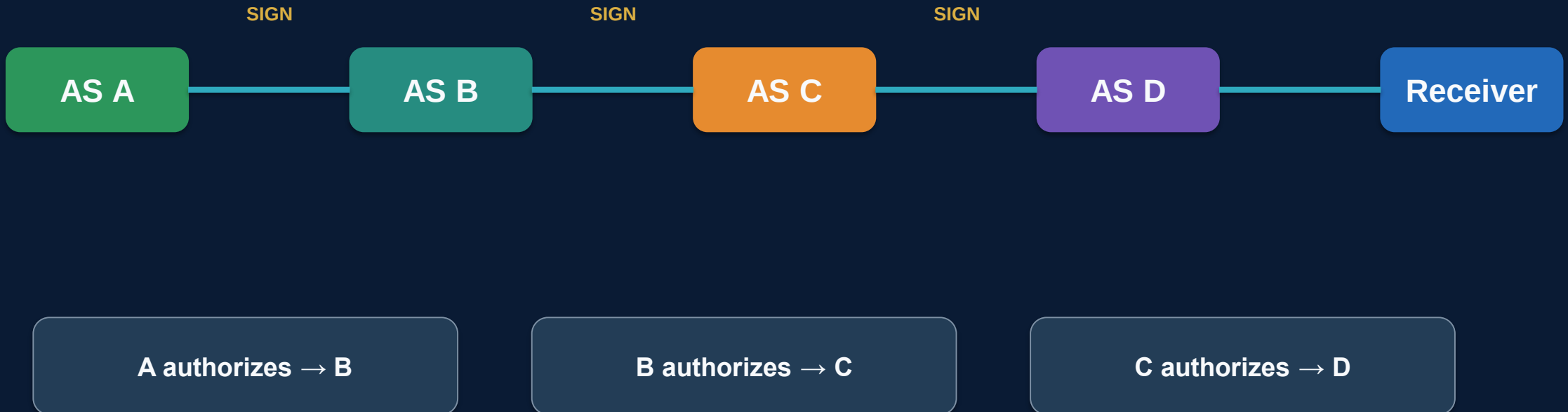
✓ Is A authorized to originate p?

✗ Did B really propagate to C?

✗ Is the AS_PATH cryptographically authentic?

This gap motivates
BGPsec

BGPsec: protect the propagation path



A valid BGPsec UPDATE gives cryptographic assurance that each protected AS explicitly authorized advertisement to the subsequent AS.

Important refinement: A does not sign “I own p” inside BGPsec

ROA / ROV

**Prefix holder authorizes
AS A to originate p**

Origin authorization

BGPsec

**AS A signs protected
propagation toward AS B**

Path authorization

Together: authorized origin + protected path propagation

Your scenario: malicious B reroutes through malicious E

Original path



B chooses another real propagation



D can validate
 $A \rightarrow B \rightarrow E \rightarrow D$

If B really sends to E and E really sends to D, the path can be cryptographically valid—even if B and E are malicious.

19 What can one malicious BGPsec AS do?

Action by malicious AS B	BGPsec permits?
Forge A's signature	NO
Invent E and forge E's signature	NO
Rewrite protected prior path arbitrarily	NO
Sign its own propagation	YES
Actually send the route to a real E	YES
Drop / misroute data-plane traffic	YES
Make a malicious local-policy choice	YES

BGPsec authenticates protected propagation; it does not make an AS honest.

What BGPsec does — and does not — promise

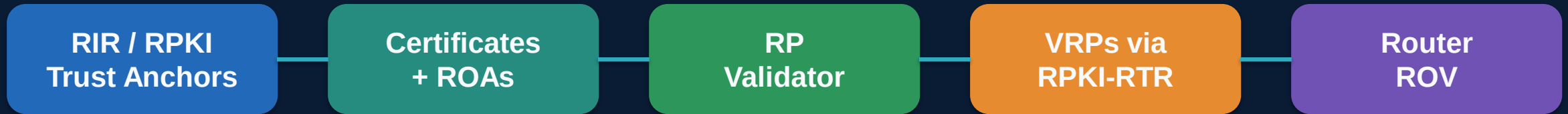
Provides

- Cryptographic evidence of protected AS propagation
- Resistance to forged protected path segments
- Strong complement to origin validation

Does not provide

- Proof that an AS is benevolent
- Proof that data-plane forwarding matches control plane
- A guarantee that the chosen route is optimal
- Protection when required signatures are absent

Put the whole system together



BGP propagation



ROV answers ORIGIN • BGPsec protects PATH

Checkpoint: can you answer these?

1. Why doesn't a router ask the RP for every BGP UPDATE?

2. What exactly is stored on the router: ROAs or VRPs?

3. Why can ROV accept a route whose AS path has been manipulated?

4. Why can't malicious B simply invent E in a valid BGPsec path?

5. Why can $A \rightarrow B \rightarrow E \rightarrow D$ still be valid if B and E are malicious?

The mental model to keep

RPKI

Who has cryptographic authority over Internet resources?

ROA

Which AS is authorized to originate this prefix?

RP → VRP

Validate heavy PKI objects; export compact results.

ROV

Compare BGP origin against local VRPs.

BGPsec

Cryptographically protect AS-to-AS propagation.

Authentication ≠ honesty.

BGPsec can prove who authorized protected propagation; it cannot prove their intentions.

Selected references

Core standards

RFC 6480 — RPKI Architecture
RFC 6482 — Route Origin Authorization profile
RFC 8210 — RPKI-to-Router protocol
RFC 8205 — BGPsec Protocol Specification
RFC 8209 — BGPsec Router Certificate Profile

Case studies

RIPE NCC RIS — YouTube Hijacking (2008)

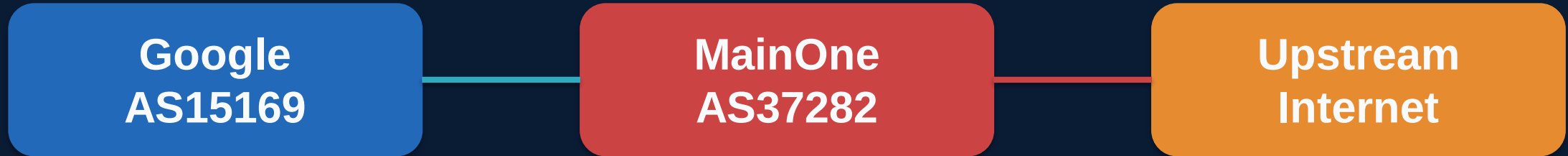
Cloudflare — How a Nigerian ISP Accidentally Knocked Google Offline (2018)

Instructor suggestion

Follow with ASPA / route-leak prevention and real-world RPKI deployment.

Case Study Deep Dive: MainOne / Google

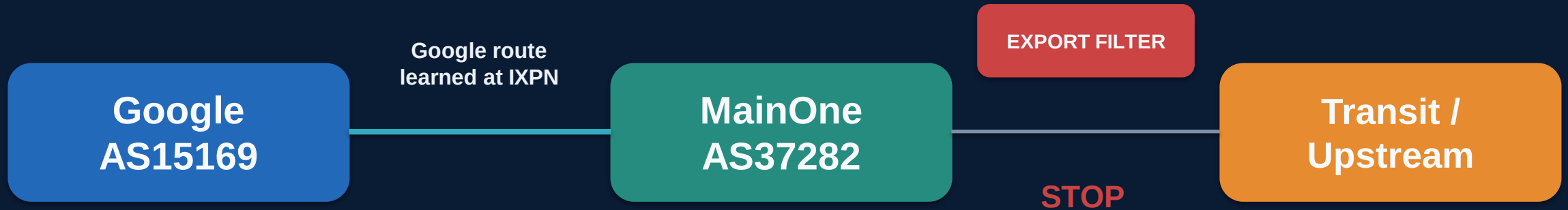
12 November 2018 • a route leak, not an origin hijack



**The route was legitimate.
The export policy was not.**

This distinction is the key to understanding why ROV alone cannot stop every routing incident.

1. Normal state: learn the Google route, but do not leak it



MainOne may use the route to reach Google.
That does not mean it should offer transit to Google through every neighbor.

2. The failure: an export-policy mistake leaks the route



Observed affected AS path example: 20485 4809 37282 15169

Origin is still Google: AS15169

3. Consequence: remote networks start selecting the leaked path



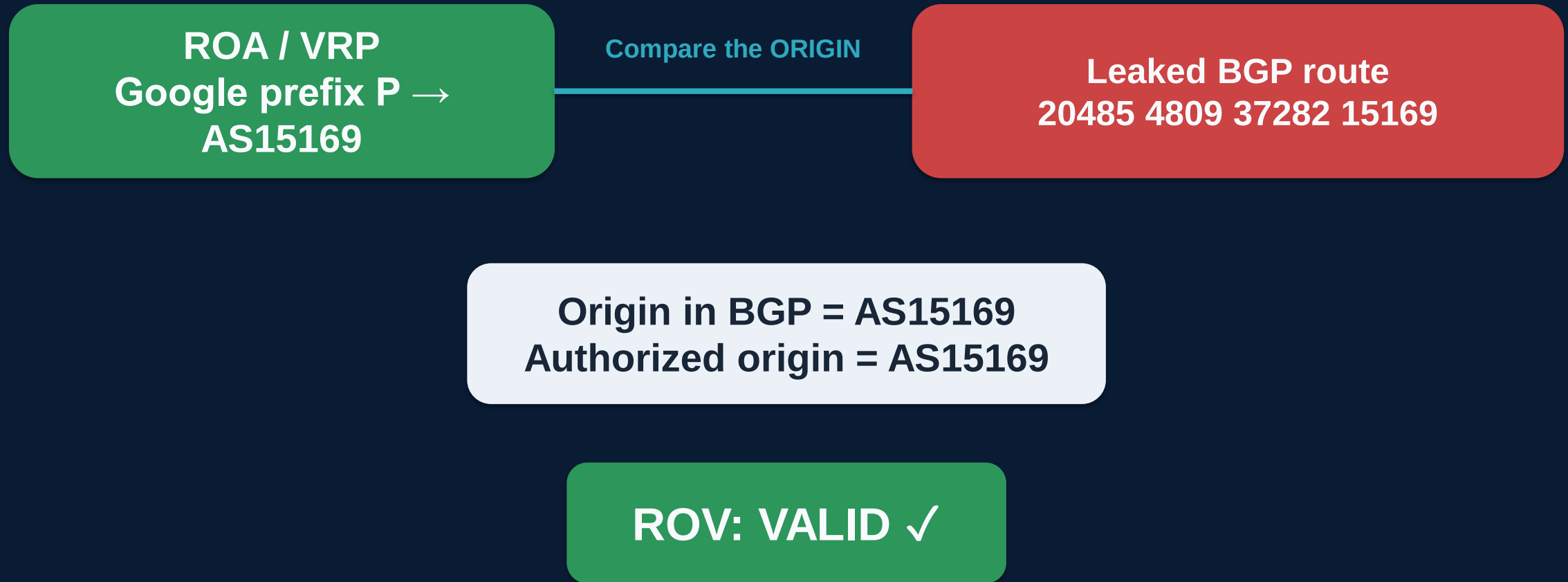
Traffic follows the control-plane decision

**Unexpected long paths
and overloaded intermediaries**

**Some destinations became
unreachable / black-holed**

Incident duration: roughly 74 minutes

4. Why ROV can still say VALID



ROV does not encode “MainOne must not export this peer-learned route to this provider.”

5. Security lesson from the MainOne case

ROV

Checks whether the origin AS is authorized.

MainOne leak: not enough

BGPsec

Protects authenticated AS-path propagation.

Different security property

Policy / leak prevention

Controls which learned routes may be exported.

Core operational defense

Route leaks are fundamentally about propagation policy—not merely who owns the prefix.

Modern leak defenses also include mechanisms such as BGP Roles / OTC and strong import/export filtering.

MainOne / Google case-study references

1. Internet Society — Route Leak Caused a Major Google Outage (2018)

2. Cloudflare — How a Nigerian ISP Accidentally Knocked Google Offline (2018)

3. ThousandEyes — Internet Vulnerability Takes Down Google (2018)

4. Google / MainOne public incident statements as summarized by the above sources

Case-study purpose: distinguish origin hijacking from policy-based route leakage.